

A Reference Architecture for LLM-Assisted Bank Transfers under AI Governance Constraints

Extended Explanation and Supplementary Data

I. REGULATORY REQUIREMENTS SYNTHESIS

To ensure that the risk classification is not based on subjective judgment, this study adopts the risk categories from the National Institute of Standards and Technology (NIST) AI Risk Management Framework and its Generative AI Profile as it is widely recognized, aligns with global AI governance practices, and is used as a reference for the AI governance

issued by the Indonesian Financial Services Authority (Otoritas Jasa Keuangan or OJK).

These risks were then mapped against key Indonesian regulations and guidelines, specifically POJK 11/2022, UU PDP 27/2022, SE Menkominfo 9/2023, and the OJK AI Governance framework. These regulations serve as constraints and design guidance for the proposed architecture (See table I).

TABLE I. RISK-REGULATION MATRIX

Risk Category (NIST)	Case Example (Bank Transfer Feature)	POJK 11/2022 (Sectoral)	UU PDP 27/2022 (Data Privacy)	SE Menkominfo 9/2023 (AI Ethics)
Confabulation	The LLM hallucinates or incorrectly extracts transfer data (account number, transfer amount) to be executed.	Article 15: Banks are required to implement risk management effectively and conduct it in an integrated manner in every stage of IT implementation. Article 39 point 3: IT-based transaction processing can be carried out by IT service providers in the territory of Indonesia as long as it fulfills the prudential principle and pays attention to customer protection aspects. Article 43 + Elucidation of Article 43: Banks are required to manage data effectively in Bank data processing by paying attention to data quality (reliability and accuracy), data management systems, and data management supporting resources.	Article 16 point 2-d: Personal Data Processing (display, announcement, transfer, etc.) is carried out accurately, completely, not misleadingly, and accountably. Article 29: Personal Data Controllers are required to ensure the accuracy and consistency of Personal Data, and are required to conduct verification.	Contents of the circular letter point b-6: Information generated through Artificial Intelligence must be trustworthy and accountably. Contents of the circular letter point c-2-b: Ensuring Artificial Intelligence is not held as a policy determinant and/or decision maker concerning humanity.
Data Privacy	The LLM model leaks account information or transaction history of other customers due to data memorization from previous chat sessions.	Article 16: Banks are required to ensure information security is implemented effectively and efficiently. Articles 44 and 45: Banks are required to implement personal data protection principles in processing personal data.	Article 16 point 2-e: Personal Data Processing is carried out by protecting the security of Personal Data from unauthorized access, unauthorized disclosure. Article 36: In processing Personal Data, the Personal Data Controller is required to maintain the confidentiality of Personal Data. Article 39: The Personal Data Controller is required to prevent Personal Data from being accessed in an unauthorized manner. Article 65 point 2: Every Person is prohibited from unlawfully disclosing Personal Data that does not belong to them.	Contents of the circular letter point b-3: The implementation of Artificial Intelligence needs to pay attention to user security aspects and the data used in order to maintain privacy, personal data. Contents of the circular letter point b-7: The implementation of Artificial Intelligence must ensure personal data protection in accordance with the provisions of laws and regulations. Contents of the circular letter point c-1-f: The implementation of Artificial Intelligence that maintains data privacy.
Human-AI Configuration	Customers confirm the transfer confirmation screen without carefully	Article 39 point 3: IT-based transaction processing can be carried out by IT service		Contents of the circular letter point c-1-b: The implementation of education

	verifying the details because psychologically they over-rely on or over-trust the AI.	providers in the territory of Indonesia as long as it fulfills the prudential principle and pays attention to customer protection aspects.		related to the Implementation of Artificial Intelligence to the public. Contents of the circular letter point c-2-b: Ensuring Artificial Intelligence is not held as a policy determinant and/or decision maker concerning humanity.
Information Security	A socially-engineered prompt injection, disguised as technical code, tricks the LLM into overriding instructions and silently change the target account.	Article 21: Banks are required to maintain cyber resilience.	Article 16 point 2-e: Personal Data Processing is carried out by protecting the security of Personal Data from unauthorized access, unauthorized disclosure, unauthorized alteration, misuse, destruction, and/or loss of Personal Data. Article 39: The Personal Data Controller is required to prevent Personal Data from being accessed in an unauthorized manner.	Contents of the circular letter point b-3: The implementation of Artificial Intelligence needs to prioritize the rights of Electronic System users so that no party is harmed. Contents of the circular letter point c-2-b: Ensuring Artificial Intelligence is not held as a policy determinant and/or decision maker concerning humanity. Contents of the circular letter point c-2-e: Carrying out the regulatory obligations of Artificial Intelligence Implementation with the aim of maintaining security and user rights in digital media. Contents of the circular letter point c-1-d: Supervision is carried out by the Government, organizers, and users to prevent the misuse and/or utilization of Artificial Intelligence-based technology that violates the provisions of laws and regulations.
Value Chain & Component Integration	Relying entirely on a third-party LLM (vendor lock-in) as a black-box reduces the bank's ability to oversee data processing and maintain accountability.	Article 29: Banks that use IT service providers are required to have the capability to supervise the implementation of Bank activities organized by IT service providers.	Article 51: Personal Data Processing is the responsibility of the Personal Data Controller.	Contents of the circular letter point c-1-d: Supervision is carried out by the Government, organizers, and users to prevent the misuse and/or utilization of Artificial Intelligence-based technology that violates the provisions of laws and regulations.

II. ARTIFICIAL INTELLIGENCE GOVERNANCE BY OJK

The Artificial Intelligence Governance for Indonesian Banking document, published by the Otoritas Jasa Keuangan (OJK), serves as a minimum reference for the banking sector in developing and implementing artificial intelligence systems. Therefore, this study adopts this document as a guideline for designing the proposed reference architecture to ensure alignment with OJK's recommended AI governance.

A. Personal Data Protection

To protect personal data when interacting with external LLMs, the system must implement de-identification (the process of reducing the ability to link data to a specific individual) by removing, masking, or replacing Personally Identifiable Information (PII). According to the Artificial Intelligence Governance guidelines issued by the Otoritas Jasa Keuangan (OJK), data that has been properly de-identified is no longer considered personal data and may therefore be

shared with third parties without requiring the data owner's consent. However, strict controls are still required to prevent potential re-identification during integration or analysis, ensuring that the de-identified data cannot be reverted to personal data.

B. Human-in-the-Loop (HITL)

Financial transfers are classified as high-risk operations, as errors in this process can lead to direct financial losses for customers. Therefore, the Otoritas Jasa Keuangan (OJK) recommends implementing a Human-in-the-Loop (HITL) mechanism for the final decision-making process. Banks must ensure that the transfer process is not entirely automated by the LLM. Instead, it must require explicit human intervention, validation, or correction before execution.

C. Alert for Anomalous Events

In order to reduce the risk of customer losses, the system should proactively alert users when anomalous transactions are detected. For example, a high-priority alert may be

triggered if a transfer request to an unrecognized payee (i.e., an account number not previously saved) either depletes the account balance or exceeds predefined limits. This mechanism serves as an additional safeguard against potential unauthorized manipulation, including scenarios such as prompt injection discussed earlier.

D. Customer Awareness and Transparency

Given the probabilistic and non-deterministic nature of AI, as well as its ability to understand complex human language and generate human-like responses, the front-end interface should explicitly inform users that they are interacting with an AI system. Furthermore, the system should encourage users to independently verify all details of any AI-assisted transaction before execution.

E. Third-Party Dependency

The implementation of AI in the financial services sector, particularly in the banking industry, must be carried out ethically and responsibly to maximize its benefits while

mitigating potential risks, including potential third-party dependency and service provider concentration.

III. THE EXAMPLE OF JSON METADATA RESPONSE

To maintain data isolation, we recommend never returning actual data or database records to the LLM. In our proposed architecture, the system responds only with the metadata, including execution statuses, feedback, and data completeness status. For example, when a recipient name matches multiple saved accounts, the system does not expose the full list to the LLM. It responds with a JSON object containing fields such as `match_count`, `has_match`, and `selection_instruction` (see Fig. 1). Next, the LLM asks the user to clarify their choice. The list of matched accounts is presented to the user by the system, not the LLM. A similar approach is applied during data collection. The system does not share the actual values with the LLM and only informs the LLM whether the required data is complete (e.g., `"is_complete": false`, `"filled_fields": []`, etc.) and which specific data fields are still missing (e.g., `"missing_fields": ["transfer_amount"]`).

```
{
  "match_count": 3,
  "has_match": true,
  "has_single_match": false,
  "has_multiple_matches": true,
  "destination_saved_to_draft": false,
  "selection_widget_presented": true,
  "selection_required": true,
  "selection_instruction": "The selection widget is already displayed. Ask the user to choose one.",
  "has_values": false,
  "is_complete": false,
  "filled_fields": [],
  "missing_fields": [
    "destination_account_number",
    "destination_bank_name",
    "destination_account_name",
    "transfer_amount"
  ]
}
```

Fig. 1. Metadata Response Sent to the LLM

IV. UI DESIGN EXAMPLE FOR MITIGATING AUTOMATION BIAS AND OVER-RELIANCE

To mitigate the risk of Human-AI Configuration, such as automation bias and over-reliance on LLMs, this study proposes two user interface (UI) guidelines (UI design examples available in the Data Availability). They serve as digital nudges to guide user behavior, aiming to interrupt automatic responses and encourage more deliberate decision-making.

1) *Disclose AI System Identity.* The interface should inform users that they are interacting with an AI system at the beginning of every chat session to help prevent users from blindly trusting the responses. For example: “Hi, I’m Rina, your AI assistant, here to help with your banking. What would you like to do today?” (see Fig. 2).

2) *Delay Confirmation for Anomalous Transactions.* To mitigate the risk of wrong transfers caused by LLM errors (hallucinations) or manipulation (social engineering) combined with over-trust in the LLM, the system should check the transfer data collected by the LLM agent. If unusual transactions are detected, such as a request to transfer the full

daily limit to a new (unsaved) account, the system alerts the user. As illustrated in Figure 8, the system introduces a brief pause to shift users from automatic to deliberate decision-making. It displays a warning message on the summary page and disables the "Confirm" button for five seconds. This acts as a speed bump, preventing automation bias (approving transactions out of habit) and encouraging them to carefully verify the transaction details (see Fig. 3).

V. REGULATORY COMPLIANCE MATRIX

To ensure regulatory alignment, all technical controls in the architecture were mapped to the relevant risks, key Indonesian regulations, and OJK AI Governance. The mapping shows that the architecture mitigates all identified relevant risks and aligns with regulatory constraints. For example, replacing numeric data with tokens and providing only abstract metadata to LLMs limits their exposure to sensitive information. This de-identification reduces the risk of data privacy issues (e.g., the LLM memorizing or leaking personal data) and aligns with key Indonesian regulations used in this study and with OJK AI Governance on data privacy (see Table II).

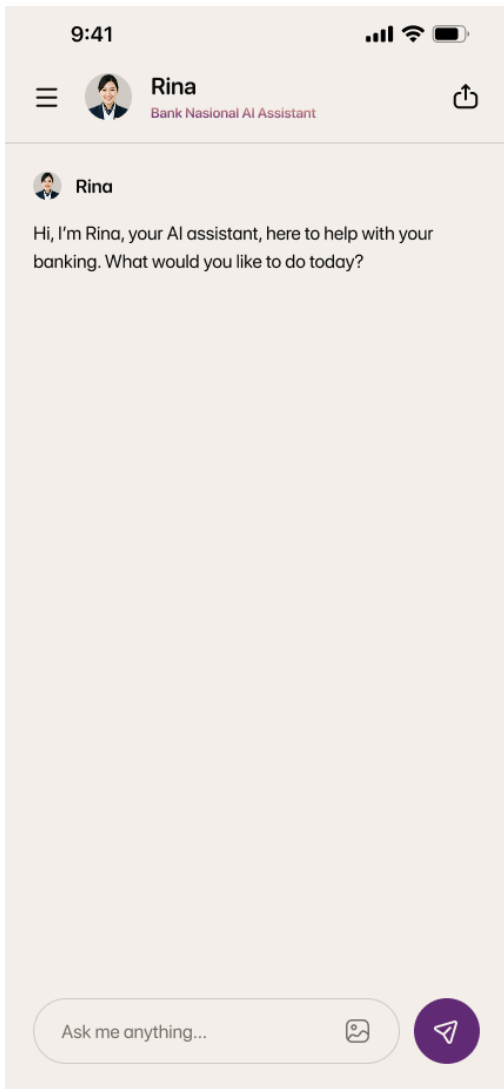


Fig. 2. Interface Disclosing AI Identity

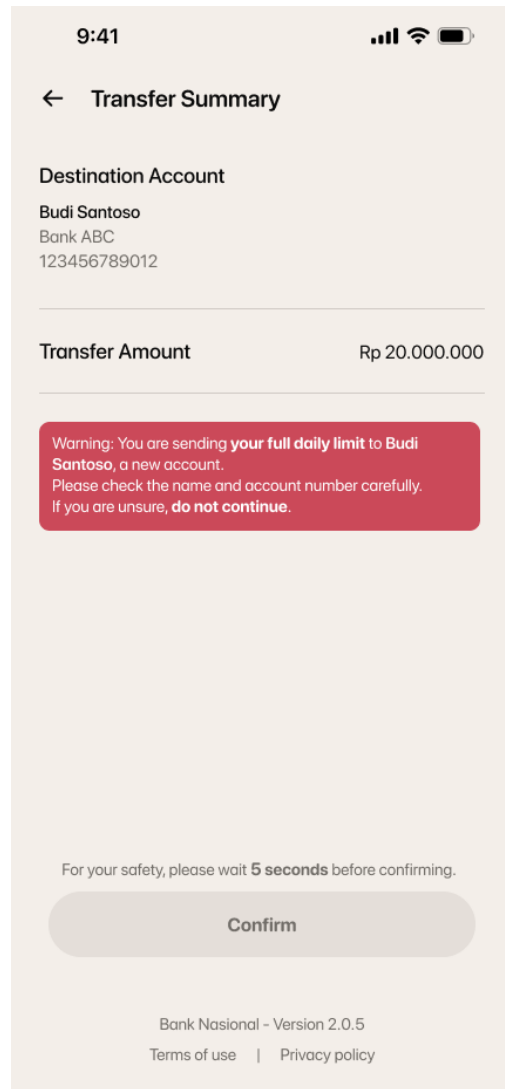


Fig. 3. Confirmation Delay for Anomalous Transactions

TABLE II. REGULATORY COMPLIANCE MATRIX

Risk Category (NIST)	Relevant Regulations	Relevant OJK AI Governance Principles	Technical Governance Controls	Expected Compliance Outcome / Analytical Proof
Confabulation	POJK 11/2022 (Sectoral): - Article 15 - Article 39 point 3 - Article 43 + Elucidation of - Article 43 UU PDP 27/2022 (Data Privacy): - Article 16 point 2-d - Article 29 SE Menkominfo 9/2023 (AI Ethics): - Contents of the circular letter point b-6 - Contents of the circular letter point c-2-b	- Human-in-the-Loop (HITL)	- LLM for Intent Recognition and Assisting User Input (A) - Format Final Responses Using Static Placeholders (B-4)	Mitigates the risk of incorrect transfer execution caused by AI hallucinations. Dedicated summary and authentication pages allow users to verify the transfer details before execution. The use of static placeholders ensures the system displays responses based on actual verified data in the App State, rather than generative text produced by the AI.
Data Privacy	POJK 11/2022 (Sectoral): - Article 16 - Articles 44 and 45 UU PDP 27/2022 (Data Privacy): - Article 16 point 2-e - Article 36 - Article 39 - Article 65 point 2	- Personal Data Protection	- Sanitize User Input (B-1) - Return Metadata Instead of Actual Data (B-3)	Replacing numeric data with tokens and providing only abstract metadata for the LLMs limits its exposure to sensitive information. This de-identifies the data, reducing the risk of the third-party model memorizing or leaking personal data.

	SE Menkominfo 9/2023 (AI Ethics): - Contents of the circular letter point b-3 - Contents of the circular letter point b-7 - Contents of the circular letter point c-1-f			
Human-AI Configuration	POJK 11/2022 (Sectoral): - Article 39 point 3 SE Menkominfo 9/2023 (AI Ethics): - Contents of the circular letter point c-1-b - Contents of the circular letter point c-2-b	- Customer Awareness and Transparency	- Disclose AI System Identity (C-1) - Delay Confirmation for Anomalous Transactions (C-2)	Making users aware that they are interacting with an AI reminds them not to blindly trust responses and to verify them. Intentional delayed confirmation prevents users from automatically or reflexively confirming transfers due to excessive trust in the AI. This encourages users to always verify, especially for suspicious transfers.
Information Security	POJK 11/2022 (Sectoral): - Article 21 UU PDP 27/2022 (Data Privacy): - Article 16 point 2-e - Article 39 SE Menkominfo 9/2023 (AI Ethics): - Contents of the circular letter point b-3 - Contents of the circular letter point c-2-b - Contents of the circular letter point c-2-e - Contents of the circular letter point c-1-d	- Human-in-the-Loop (HITL) - Alert for Anomalous Events	- LLM for Intent Recognition and Assisting User Input (A) - Delay Confirmation for Anomalous Transactions (C-2)	Restricting the LLM's role to Intent Recognition and Assisting User Input prevents the model from automatically executing transfers without explicit user verification. Intentional delayed confirmation provides a prominent alert for suspicious transactions. This encourages users to re-verify details, reducing the risk of financial loss caused by automatic, reflexive, or accidental confirmations of manipulated data.
Value Chain & Component Integration	POJK 11/2022 (Sectoral): - Article 29 UU PDP 27/2022 (Data Privacy): - Article 51 SE Menkominfo 9/2023 (AI Ethics): - Contents of the circular letter point c-1-d	- Third-Party Dependency	- Model-Agnostic Architecture - LLM for Intent Recognition and Assisting User Input (A)	Reduces vulnerability to service provider concentration. Prevents vendor lock-in by decoupling the system from any specific LLM, allowing the bank to swap between third-party AI models or an in-house LLM if a provider's service degrades or policies change.